

DESARROLLO DE SISTEMAS WEB NATIVOS DE LA NUBE (CNA)

CASO PRACTICO 10

Contexto

La empresa FastMarket S.A.C. es una cadena peruana de supermercados que recientemente desarrolló una plataforma web para la venta de productos en línea. Debido al incremento de ataques informáticos reportados por sus clientes, la gerencia ha contratado a un equipo externo de consultores (los estudiantes) para realizar una evaluación integral de seguridad basada en las recomendaciones de OWASP.

Durante las últimas semanas se han reportado diversos incidentes:

- Usuarios ingresan datos inesperados en los formularios.
- Se detectaron accesos no autorizados a cuentas de clientes.
- Algunos clientes visualizaron información perteneciente a otros usuarios.
- La aplicación permite cargar archivos sin restricciones.
- Se encontraron consultas SQL construidas mediante concatenación.
- Las cookies de sesión no poseen atributos de seguridad.
- Existen páginas administrativas accesibles únicamente modificando la URL.
- Los mensajes de error muestran información técnica del servidor.
- No existe registro de eventos de seguridad.
- No se utiliza HTTPS en todo el sitio.

La gerencia solicita un informe técnico con una propuesta integral para fortalecer la seguridad de la plataforma.

Objetivo General

Analizar una aplicación web vulnerable, identificar los riesgos utilizando las buenas prácticas de OWASP y proponer una arquitectura de seguridad que elimine o reduzca las vulnerabilidades detectadas.

Objetivos específicos

Los estudiantes deberán ser capaces de:

- Identificar vulnerabilidades siguiendo OWASP Top 10.
- Clasificar el nivel de riesgo de cada vulnerabilidad.
- Diseñar controles de seguridad.
- Implementar mejoras sobre fragmentos de código.
- Validar la efectividad de las soluciones propuestas.
- Elaborar documentación técnica.
- Presentar evidencias mediante pruebas.

Escenario técnico

La aplicación posee los siguientes módulos:

- Inicio de sesión
- Registro de usuarios
- Catálogo de productos
- Carrito de compras
- Pago en línea
- Panel administrativo

DESARROLLO DE SISTEMAS WEB NATIVOS DE LA NUBE (CNA) CASO PRACTICO 10

- Gestión de productos
- Gestión de usuarios
- Carga de imágenes
- Reportes

Tecnologías utilizadas

- HTML
- CSS
- JavaScript
- PHP
- MySQL

Vulnerabilidades detectadas

Cada grupo deberá analizar las siguientes situaciones.

Caso 1

SQL Injection

Código encontrado

 PHP

```
$sql="SELECT * FROM usuarios  
WHERE usuario='$usuario'  
AND password='$password';
```

Caso 2

Cross Site Scripting (XSS)

El formulario de comentarios acepta el siguiente texto:

 HTML

```
<script>alert('Hack')</script>
```

y posteriormente es mostrado a todos los usuarios.

Caso 3

Broken Access Control

Un usuario cambia la siguiente URL

```
/cliente/perfil.php?id=35
```

Por

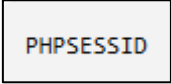
```
/cliente/perfil.php?id=12
```

y puede visualizar la información de otro cliente.

Caso 4

Gestión insegura de sesiones

Las cookies contienen únicamente



PHPSESSID

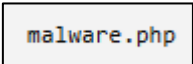
sin atributos:

- HttpOnly
- Secure
- SameSite

Caso 5

Carga de archivos

La aplicación acepta archivos



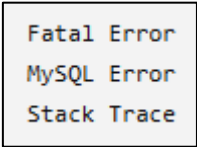
malware.php

Sin ninguna validación.

Caso 6

Configuración insegura

Al producirse un error SQL aparece



Fatal Error
MySQL Error
Stack Trace

Caso 7

Falta de HTTPS

El formulario de login transmite usuario y contraseña mediante HTTP.

Caso 8

Ausencia de registros

No existe ningún mecanismo para registrar:

- intentos fallidos
- cambios de contraseña
- acceso de administradores
- modificaciones de productos

Caso 9

Autenticación débil

Las contraseñas se almacenan en texto plano.

Caso 10

Consultas sin validación

Todos los formularios aceptan:

- caracteres especiales
- etiquetas HTML
- scripts
- consultas SQL

Actividades a desarrollar

Primera actividad

Análisis

Cada grupo deberá:

- Identificar todas las vulnerabilidades.
- Clasificarlas según OWASP Top 10.
- Determinar el impacto para la empresa.
- Calcular el nivel de riesgo.

Producto esperado:

Una matriz de riesgos.

Segunda actividad

Diseño de la solución

Cada grupo deberá proponer:

- Arquitectura de seguridad.
- Controles preventivos.
- Controles detectivos.
- Controles correctivos.

El diseño deberá incluir:

- autenticación
- autorización
- validación
- cifrado
- sesiones
- monitoreo
- registros
- manejo de errores

Producto esperado: Diagrama de arquitectura.

Tercera actividad

Desarrollo

Cada grupo deberá modificar los fragmentos vulnerables implementando:

- consultas parametrizadas
- validación de datos
- sanitización
- hash de contraseñas
- control de sesiones
- validación de archivos
- mensajes de error personalizados

Producto esperado: Código corregido.

Cuarta actividad

Validación

Cada grupo deberá demostrar la efectividad mediante pruebas.

Ejemplos:

Intento de SQL Injection

```
' OR '1'='1
```

Intento de XSS

```
HTML  
<script>alert(1)</script>
```

Carga de archivo

```
virus.php
```

Cambio manual de URL

```
?id=15
```

Intento de acceso sin autenticación.

Producto esperado: Evidencias antes y después de la implementación.

Quinta actividad

Informe Final

Cada grupo deberá elaborar un informe técnico que contenga:

- Introducción.
- Diagnóstico.
- Vulnerabilidades encontradas.
- Clasificación OWASP.
- Riesgos.
- Solución propuesta.
- Evidencias.
- Conclusiones.
- Recomendaciones.

Entregables

Cada grupo entregará:

- Informe técnico.
- Código corregido.
- Diagrama de arquitectura.
- Matriz de riesgos.
- Evidencias de pruebas.

Productos esperados al finalizar el trabajo

Al concluir la actividad, cada grupo deberá presentar:

1. **Diagnóstico de seguridad** de la aplicación con las vulnerabilidades identificadas y clasificadas según OWASP Top 10.
2. **Matriz de riesgos** priorizada, indicando impacto, probabilidad y nivel de criticidad.
3. **Arquitectura de seguridad propuesta**, incorporando controles de autenticación, autorización, validación, gestión de sesiones, cifrado, manejo de errores, registro de eventos y comunicaciones seguras.
4. **Código corregido** o pseudocódigo funcional que evidencie la implementación de las mejoras.
5. **Plan de pruebas de seguridad**, con casos de prueba y resultados antes y después de aplicar los controles.
6. **Conclusiones y recomendaciones**, justificando técnicamente cómo las soluciones implementadas reducen los riesgos identificados.